STRIDE ISP 3.2 – ID.RA

Risk Assessment Standards

Version [2.0]

Purpose:

This document defines the Stride standards related to Risk Assessment.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested, using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	6/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
2.0	02/07/2025	- Updated Policy Title - Updated Policy to match NIST 2.0 Release Changes - Updated Publication Owners
2.0	02/27/2025	- Published

RISK ASSESSMENT STANDARDS

Stride thoroughly understands and addresses cybersecurity risks to the organization, its assets, and individuals.

ID.RA-01: ASSET VULNERABILITIES IDENTIFICATION

Vulnerabilities in assets are identified, validated, and recorded.

Standards:

- A documented vulnerability management process for enterprise assets is established and maintained:
    - Monitoring and scanning for vulnerabilities in organizational systems and applications are employed, scans are completed at least monthly.
    - Vulnerability scans are conducted utilizing Various tools and technologies and may include other tools at the discretion of leadership to meet business needs.
    - Vulnerabilities are documented when identified:
        - New vulnerabilities are reported via defined communication channels.
        - A risk ranking is assigned and documented for any newly discovered security vulnerabilities.
    - Vulnerabilities are kept confidential and revealed on a limited basis to authorized personnel assisting in remediation activity or who need to understand the risk to the organization of discovered vulnerabilities.
    - Documentation is reviewed and updated, at a minimum annually, or when significant enterprise changes occur that could impact this safeguard.
- Stride identifies, assesses, and documents risks, and potential vulnerabilities associated with assets, including workforce, data, technology, facilities, services, and connections.
- Stride's business units ensure that information regarding cyber risk is shared with the appropriate level of senior management promptly so that they can address and respond to emerging cyber risks.
- Stride establishes and maintains standards and capabilities for ongoing vulnerability management, including systematic scans, or reviews designed to

identify known cyber vulnerabilities and upgrade opportunities, across the organization's environments and assets.

- A vulnerability management plan is developed and implemented.
- Vulnerability scans are performed.

References:

- SP 800-218: PO.5.2
- CIS Controls v8.0: 7.1
- CRI Profile v2.0: ID.RA-01
- CRI Profile v2.0: ID.RA-01.01
- CRI Profile v2.0: ID.RA-01.02
- CRI Profile v2.0: ID.RA-01.03
- SP 800-221A: MA.RI-3
- CSF v1.1: ID.RA-1
- CSF v1.1: PR.IP-12
- CSF v1.1: DE.CM-8

ID.RA-02: THREAT INTELLIGENCE

Cyber threat intelligence is received from information-sharing forums and sources.

Standards:

- Stride maintains situational awareness of evolving threats by leveraging the knowledge of attacker tactics, techniques, and procedures to facilitate the implementation of preventative and compensating controls.
- Contact is established with selected groups and associations within the security and privacy communities, including but not limited to:
    - Local Cybersecurity Groups and Unions (i.e., The Cloud Security Alliance)

    - ISACA
    - ISC^2
    - InfraGard

- Ongoing security and privacy education and training for organizational personnel is facilitated.

- Threat Intelligence sourcing and processes are evaluated, at minimum, annually to determine any need for change or updating.

- Stride actively participates in information-sharing groups and collectives (e.g., cross-industry, cross-government, and cross-border groups) aligned with its business operations, inherent risks, and organizational complexity.to gather, distribute, and analyze information about cyber practices, cyber threats, and early warning indicators relating to cyber threats.

- Stride shares authorized information regarding its cyber resilience framework and the effectiveness of its protection technologies bilaterally with trusted external stakeholders to promote the understanding of each party's approach to securing systems.

References:

- CRI Profile v2.0: ID.RA-02
- CRI Profile v2.0: ID.RA-02.01
- CRI Profile v2.0: ID.RA-02.02
- SP 800-221A: GV.BE-4
- CSF v1.1: ID.RA-2

ID.RA-03: THREAT IDENTIFICATION & DOCUMENTATION

Threats, both internal and external, are identified and documented.

Standards:

- Stride utilizes external and internal threat intelligence feeds to determine legitimate threats to the organization and to determine which threats require mitigation.

- Threats to critical products and services are identified and documented.
- Threats are formally documented in the organization's risk register by qualified personnel.
- Threats are assigned a risk ranking:
  - The risk ranking shall be aligned with Stride's risk assessment methodology.
  - The likelihood of attack and potential impact are considered.
  - Exposure and attack surface is considered.
- Threat identification processes are reviewed, at minimum, annually.

- Stride, on an ongoing basis, identifies, analyzes, correlates, characterizes, and reports both internal and external threats to the organization.
- Stride solicits and considers threat intelligence from the organization's stakeholders, service, and utility providers, as well as other industry and security organizations.
- Stride includes in its threat analysis those cyber threats that could trigger extreme but plausible cyber events, even if they are deemed unlikely or have never occurred in the past.
- Stride regularly reviews and updates its threat analysis methodology, threat information sources, and supporting tools.

References:

- CRI Profile v2.0: ID.RA-03
- CRI Profile v2.0: ID.RA-03.01
- CRI Profile v2.0: ID.RA-03.02
- CRI Profile v2.0: ID.RA-03.03
- CRI Profile v2.0: ID.RA-03.04
- SP 800-221A: MA.RI-2
- CSF v1.1: ID.RA-3

ID.RA-04: BUSINESS IMPACT AND LIKELIHOOD ANALYSIS

Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded.

Standards:

- A Business Impact Analysis (BIA) is conducted at least annually or when significant enterprise changes occur that could impact this safeguard.
    - The Business Impact Analysis (BIA) is conducted by qualified and authorized personnel within the organization.
        - Personnel may include individuals from the following departments, but not limited to:
            - Information Technology
            - Information Security and Cybersecurity Operations
            - Human Resources
            - School Operations
            - Stride Corporate
    - Operational dependencies on critical products and services are understood and documented.
    - Impacts resulting from planned and unplanned disruptions are identified and documented.
    - The likelihood of impact on critical business functions is understood and identified.
- Stride's risk assessment approach includes the analysis and characterization of the likelihood and potential business impact of identified risks being realized.
- Stride ensures that the BIA and Risk Assessment processes are reviewed and updated to reflect changes in the threat landscape and organizational priorities.

References:

- CRI Profile v2.0: ID.RA-04

- CRI Profile v2.0: ID.RA-04.01
- SP 800-221A: MA.RI-4
- CSF v1.1: ID.RA-4

ID.RA-05: RISK DETERMINATION AND PRIORITIZATION

Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization.

Standards:

- Risk assessments are:
    - Conducted by authorized personnel
    - Personnel may include individuals from the following departments, but not limited to:
        - Information Technology
        - Information Security and Cybersecurity Operations
        - Human Resources
        - School Operations
        - Stride Corporate
    - Utilize known and discovered threats, vulnerabilities, likelihood, and potential impacts to determine the risk to the organization and operations.
    - Completed at a minimum annually or when significant changes occur within the organization.
- Threats, vulnerabilities, likelihoods, and impacts are used to determine overall technology, cybersecurity, and risk to the organization.
- Stride has established threat modeling capabilities to identify how and why critical assets might be compromised by a threat actor, what level of protection is needed for those critical assets, and what the impact would be if that protection failed.

- Stride's business units assess, on an ongoing basis, the technology, cybersecurity, and resilience risks associated with the activities of the business unit.

- Stride uses scenario planning, table-top exercises, or similar event analysis techniques to identify vulnerabilities and determine potential impacts to critical infrastructure, technology, and business processes.

References:

- Risk = Threat x Vulnerability

    - Risk – the fact that undesired events can happen that may damage property or disrupt operations; specifically, an event scenario that can result in property damage or disruption.

    - Threat – an event that if realized could bring harm to an asset.

    - Vulnerability – A weakness that can be exploited by a threat.

- SP 800-218: PW.1.1

- CRI Profile v2.0: ID.RA-05

- CRI Profile v2.0: ID.RA-05.01

- CRI Profile v2.0: ID.RA-05.02

- CRI Profile v2.0: ID.RA-05.03

- CRI Profile v2.0: ID.RA-05.04

- SP 800-221A: MA.RA-2

- CSF v1.1: ID.RA-5

ID.RA-06: RISK RESPONSE DETERMINATION

Risk responses are chosen, prioritized, planned, tracked, and communicated

Standards:

- Stride bases Risk Response activities based on two defining components of Risk Tolerance: Impact and Likelihood.

- Impact is scored based on five levels of financial loss probability, including:

Score	Scale	Description
1	Low	Financial loss up to $1 million; Negligible reputational impact; Not reportable to the regulator.
2	Moderate	Financial loss greater than $1 million up to $5.9 million; Limited reputational impact; Reportable incident to the regulator, no follow-up.
3	High	Financial loss greater than $5.9 million up to $12.9 million; Limited external reputational impact; report of the breach to the regulator with an immediate correction to be implemented.
4	Significant	Financial loss greater than $12.9 million up to $25.9 million; Report to regulator requiring major project for correction action.
5	Critical	Financial loss greater than $25.9 million; Significant external reputational impact; game-changing loss of market share; Significant prosecution and fines.

- Likelihood is scored on five levels regarding the probability of occurrence, including:

Score	Scale	Description
1	Remote	Once in 20 years or less.
2	Rare	Once in 10 years up to once in 20 years.
3	Unlikely	Once in 5 years up to once in 10 years.
4	Possible	Once in 2 years up to once in 5 years.
5	Probable	Up to once in 2 years or more.

- Impact and Likelihood scores are combined to determine overall risk ranking.
  - Risks are prioritized based on risk rankings to ensure the highest-level risks receive priority attention and treatment.
- Planned remediation actions are documented and executed to correct weaknesses or deficiencies noted during risk assessment and to reduce or eliminate known vulnerabilities in the system.
- Technology and cybersecurity risk management programs and risk assessment processes produce actionable recommendations that the organization uses to select, design, prioritize, implement, maintain, evaluate, and modify cybersecurity and technology controls.

- The implementation of responses to address identified risks (i.e., risk avoidance, risk mitigation, risk acceptance, or risk transfer (e.g., cyber insurance)) are formulated, assessed, documented, and prioritized based on criticality to the business.

- Stride ensures that its technology and cybersecurity programs identify and implement controls to manage applicable risks within the risk appetite set by the governing authority (e.g., the Board or one of its committees).

- Stride evaluates the threats, impacts, and risks that could adversely affect the organization's ability to provide services on an ongoing basis, and develops its resilience requirements and plans to address those risks.

- Stride adheres to documented procedures that align with established risk response processes, for mitigating or accepting the risk of vulnerabilities or weaknesses identified in exercises and testing or when responding to incidents.

- Newly identified vulnerabilities are mitigated or documented as accepted risks.

References:

- SP 800-218: PO.5.2
- CRI Profile v2.0: ID.RA-06
- CRI Profile v2.0: ID.RA-06.01
- CRI Profile v2.0: ID.RA-06.02
- CRI Profile v2.0: ID.RA-06.03
- CRI Profile v2.0: ID.RA-06.04
- CRI Profile v2.0: ID.RA-06.05
- CRI Profile v2.0: ID.RA-06.06
- SP 800-221A: MA.RP
- CSF v1.1: ID.RA-6
- CSF v1.1: RS.MI-3

ID.RA-07: CHANGE AND EXCEPTION MANAGEMENT

Changes and exceptions are managed, assessed for risk impact, recorded, and tracked.

Standards:

- Stride defines and implements change management standards and procedures, including emergency change procedures, that explicitly address risk identified both before and during a change, any new risk created post-change, as well as the reviewing and approving authorities (e.g., change advisory boards).

- Risk-based criteria are used to categorize each system change, to include emergency changes, and to determine the necessary change process standards to apply for change planning, rollback planning, pre-change testing, change access control, post-change verification, and change review and approval.

- Technology projects and system change processes ensure that requisite changes in security posture, data classification and flows, architecture, support documentation, business processes, and business resilience plans are addressed.

- Policy exceptions, risk mitigation plans, and risk acceptances resulting from assessments and evaluations, such as testing, exercises, audits, etc., are formally managed, approved, escalated to defined levels of management, and tracked to closure.

- Stride establishes and maintains an exception management process for identified vulnerabilities that cannot be mitigated within target timeframes.

- Configuration change control and change management processes are in place.

References:

- SP 800-218: PO.5.2

- CRI Profile v2.0: ID.RA-07

- CRI Profile v2.0: ID.RA-07.01

- CRI Profile v2.0: ID.RA-07.02

- CRI Profile v2.0: ID.RA-07.03

- CRI Profile v2.0: ID.RA-07.04

- CRI Profile v2.0: ID.RA-07.05
- SP 800-221A: MA.RI-3
- CSF v1.1: PR.IP-3

ID.RA-08: VULNERABILITY DISCLOSURE RESPONSE

Processes for receiving, analyzing, and responding to vulnerability disclosures are established.

Standards:

- Stride has established enterprise processes for soliciting, receiving, and appropriately channeling vulnerability disclosures from:
    - Public sources (e.g., customers and security researchers)
    - Vulnerability sharing forums (e.g., FS-ISAC)
    - Third parties (e.g., cloud vendors)
    - Internal sources (e.g., development teams)
- Stride has established enterprise processes to analyze disclosed vulnerabilities with a focus on:
    - Determining its validity
    - Assessing its scope (e.g., affected assets)
    - Determining its severity and impact
    - Identifying affected stakeholders or customers
    - Analyzing options to respond.
- Processes are established to receive, analyze, and respond to vulnerabilities disclosed to the organization from internal and external sources (e.g., internal testing, security bulletins, or security researchers).

References:

- CIS Controls v8.0: 7.2
- CRI Profile v2.0: ID.RA-08

- CRI Profile v2.0: ID.RA-08.01
- CRI Profile v2.0: ID.RA-08.02
- SP 800-221A: MA.RI-3
- CSF v1.1: RS.AN-5

ID.RA-09: PRODUCT AND SERVICE DUE DILIGENCE

The authenticity and integrity of hardware and software are assessed before acquisition and use.

Standards:

- Third-party products and services are assessed relative to business, risk management, and cybersecurity requirements
- Integrity-checking mechanisms are used to verify hardware integrity.

References:

- SP 800-218: PO.5.2
- CRI Profile v2.0: EX.DD-04
- CRI Profile v2.0: EX.DD-04.01
- CRI Profile v2.0: EX.DD-04.02
- SP 800-221A: MA.RI-3
- CSF v1.1: PR.DS-8

ID.RA-10: TECHNOLOGY AND CYBERSECURITY RISK ASSESSMENT

Critical suppliers are assessed before the acquisition.

Standards:

- Stride evaluates the risks and suitability of the technology and cybersecurity capabilities and risk management practices of prospective third parties
- Identify, prioritize, and assess suppliers and partners of critical information systems, components, and services using a cyber supply chain risk assessment process

- Suppliers and third-party partners are routinely assessed using audits, test results, or other forms of evaluations to confirm they are meeting their contractual obligations.

References:

- CRI Profile v2.0: EX.DD-03
- CRI Profile v2.0: EX.DD-03.01
- CRI Profile v2.0: EX.DD-03.02
- CRI Profile v2.0: EX.DD-03.03
- SP 800-221A: GV.CT-2
- SP 800-221A: GV.CT-3
- SP 800-221A: MA.RM-2
- SP 800-221A: MA.RM-3
- CSF v1.1: ID.SC-2
- CSF v1.1: ID.SC-4